Missió Red Team · El pretext perfecte

MÒDUL: Optativa de Ciberseguretat **GRUP:** DAW2A

NOM I COGNOMS: Komalpreet Kaur **DATA:** 10/11/2026

Exercici teòric sobre el cas Operació Far (dades fictícies). No s'envia cap correu ni es truca a ningú. Analitzo com es podria preparar un atac d'enginyeria social per aprendre a defensar-m'hi.

Tasca 1 · Mapa de persones



web/equip.html

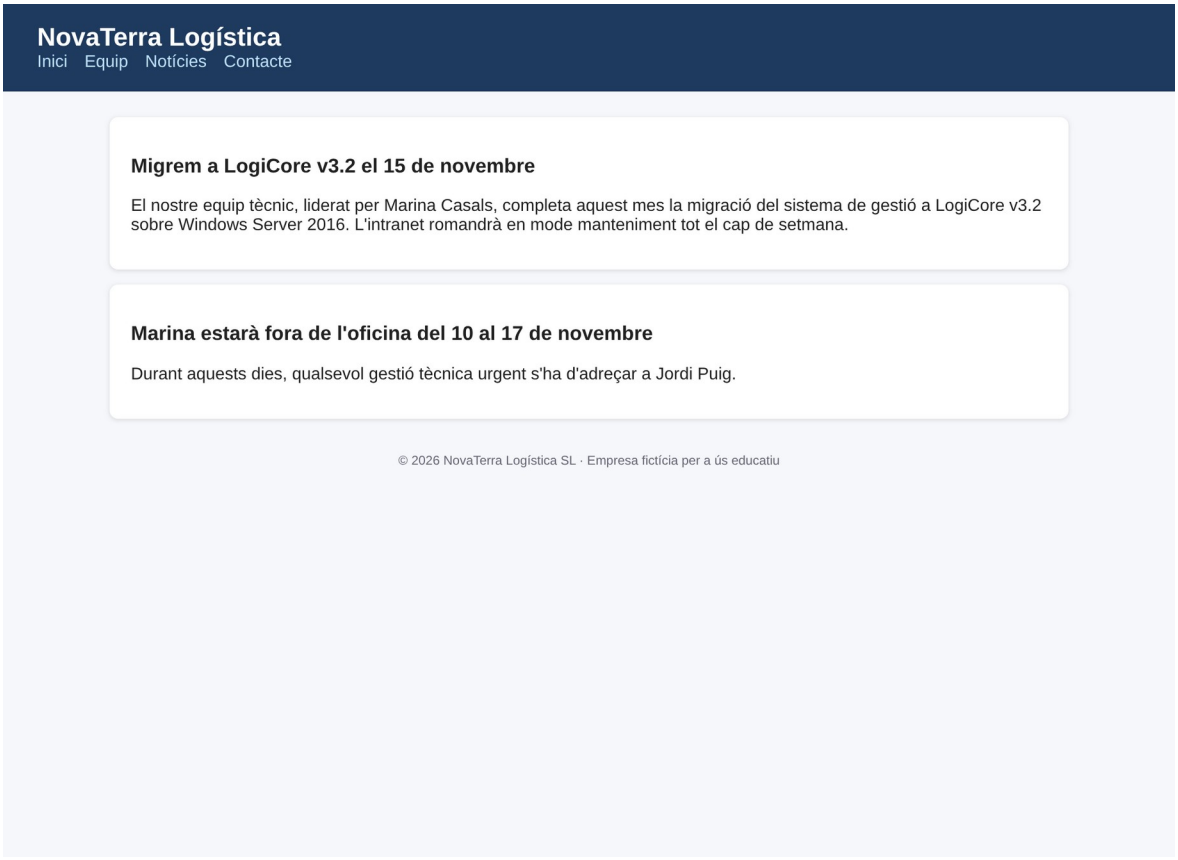
Nom	Càrrec	Correu	Info pública útil per a un atacant
Marina Casals Roig	CTO	marina.casals@novat	Molt activa a la xarxa

		erra-logistica.example	ConnectaCat; de vacances 10-17 nov; explica el seu mètode de contrasenyes
Jordi Puig Serra	Admin. de sistemes	jordi.puig@novaterra-logistica.example	Cobreix la CTO mentre és fora; admin del domini (whois)
Anna Vidal Mas	Recursos humans	anna.vidal@novaterra-logistica.example	RRHH: rep CVs i correus de persones desconegudes (bona víctima de phishing)
Pau Ribas Soler	Comptabilitat	pau.ribas@novaterra-logistica.example	Gestiona pagaments: objectiu de frau del CEO / factures falses

Flag: `FLAG{anna.vidal@novaterra-logistica.example}`

Resposta: La taula surt de la pàgina Equip. El correu de Recursos Humans (Anna Vidal) és la flag de la tasca.

Tasca 2 · Tria de l'objectiu



web/blog.html — avís que Jordi Puig cobreix la CTO

Flag: `FLAG{jordi_puig}`

Resposta: Triaria en Jordi Puig com a primer objectiu. Tres dades de fonts obertes: (1) al blog diu que «qualsevol gestió tècnica urgent s'ha d'adreçar a Jordi Puig» mentre la CTO és fora; (2) al whois_dns.txt és l'admin del domini, o sigui que té molts permisos; (3) a la xarxa social de la CTO apareix com a seguidor (@jpuig_it), així que confirmo que treballen junts. És atractiu perquè té autoritat tècnica i molts accessos, i aquests dies està sol cobrint la feina de la seva cap: té pressa i rep peticions urgents, que és quan la gent abaixa la guàrdia.

Tasca 3 · El moment i el pretext



socials/marina_connectacat.html — vacances i migració

Flag: `FLAG{15-11_10-11_17-11}`

Resposta: El millor moment és entre el 10 i el 17 de novembre, quan la CTO (Marina) és de vacances a Lisboa amb «el mòbil apagat», i just coincideix amb la migració del sistema a LogiCore v3.2 del 15 de novembre. Pretext creïble: fer-me passar pel proveïdor o per la mateixa Marina i demanar a Jordi una gestió urgent «per no aturar la migració». Funcionaria perquè hi

ha pressa, la cap no està localitzable per confirmar res i tot és molt urgent. Les tres dates clau són: migració 15-11, primer dia d'absència 10-11 i últim dia 17-11.

Tasca 4 · Contrasenyes previsibles



La CTO explica el seu mètode de contrasenyes a ConnectaCat

Flag: `FLAG{Kira1988!}`

Resposta: A la xarxa social la Marina explica ella mateixa el seu mètode: «faig servir el nom de la Kira (la seva gossa) i l'any en què vaig néixer, amb una majúscula al principi i un símbol al final». En altres publicacions diu que la gossa es diu Kira i que ella va néixer el 14 de març de 1988. Ajuntant-ho: Kira (majúscula) + 1988 + un símbol al final (!) = Kira1988!. És un exercici teòric: no provo la contrasenya enlloc. Lliçó: no s'han d'explicar públicament els mètodes per crear contrasenyes.

Tasca 5 · La filtració confirma el patró

```
root@vm:~/cas_Operacio_Far$
$ # recompte de contrasenyes Nom+AAAA+! al fitxer filtrat
$ python3 compta.py

Contrasenya de la CTO (Kira1988!) trobada a la filtracio:
marina.casals@novaterra-logistica.example,Marina Casals,Kira1988!,2023-05-14

TOTAL amb forma Nom+AAAA+!  = 61
de les quals el nom es el nom propi = 60
=> FLAG{61-60}
```

Recompte a dades/filtracio_2023_tiendaviatges.csv

Flag: **`FLAG{61-60}`**

Resposta: He obert el CSV i la contrasenya que vaig endevinar (Kira1988!) hi apareix, associada al correu de la Marina. Això demostra que reutilitza la mateixa contrasenya en llocs diferents: si es filtra en un lloc, serveix per entrar a la feina. Per fer el recompte he mirat totes les contrasenyes amb la forma Nom + any de 4 xifres + «!» (amb la primera lletra en majúscula): n'hi ha 61. D'aquestes, en 60 el nom és el nom de pila del propi usuari (l'única excepció és la Marina, que fa servir el nom de la gossa). Lliçó per a l'empresa: obligar contrasenyes llargues i úniques, activar la verificació en dos passos i no reutilitzar mai la mateixa contrasenya.

Tasca 6 · El missatge d'engany i l'SPF

Correu de phishing fictici (NO s'envia):

De: Marina Casals <marina.casals@novatera-logistica.example>
Per a: Jordi Puig [1]
Assumpte: URGENT migració LogiCore [2]

Hola Jordi,
T'escric de pressa des de Lisboa [3]. No puc trucar perquè tinc el mòbil gairebé sense bateria. Com que tu cobreixes les gestions tècniques aquests dies [4], necessito que validis l'accés del compte svc_migracio [5] abans del 15 perquè no s'aturi la migració a LogiCore v3.2 [6]. Entra en aquest enllaç i confirma les credencials. Gràcies!
Marina (CTO)

Fonts de cada element personalitzat:

- [1][4] blog.html: Jordi cobreix la CTO.
- [2][6] blog.html: migració a LogiCore v3.2 el 15-11.
- [3] social: Marina és a Lisboa de vacances.
- [5] PDF: compte de servei svc_migracio.
- Patró de correu nom.cognom (equip.html) per falsejar el remitent.

Tres senyals que és un engany:

- El domini està mal escrit: novatera- en lloc de novaterra- (li falta una r).
- Mètode estrany i amb presa: demana credencials per un enllaç, cosa que una CTO no faria.
- La Marina havia dit que estaria sense correu ni feina: no quadra que escrigui demanant accessos.

```
root@vm:~/cas_Operacio_Far$
$ cat dades/whois_dns.txt

# Dades fictícies de novaterra-logistica.example (format simplificat)

Domain Name: NOVATERRA-LOGISTICA.EXAMPLE
Registrar: CatDomains Registrar SL
Creation Date: 2015-04-02
Registrant Organization: NovaTerra Logística SL
Registrant Email: jordi.puig@novaterra-logistica.example
Admin Name: Jordi Puig Serra
Name Server: ns1.cloudcat.example
Name Server: ns2.cloudcat.example

;; DNS records
novaterra-logistica.example.        A       198.51.100.20
www.novaterra-logistica.example.    CNAME   novaterra-logistica.example.
mail.novaterra-logistica.example.   A       198.51.100.25
intranet.novaterra-logistica.example. A     198.51.100.30
test.novaterra-logistica.example.   A       198.51.100.31
novaterra-logistica.example.        MX 10   mail.novaterra-logistica.example.
novaterra-logistica.example.        TXT     "v=spf1 ip4:198.51.100.25 ~all"
_dev.novaterra-logistica.example.   TXT     "FLAG{el_dns_te_pistes_amagades}"
```

Registre SPF a dades/whois_dns.txt

Flag: `FLAG{198.51.100.25~all}`

Resposta: El registre SPF és v=spf1 ip4:198.51.100.25 ~all. Només autoritza la IP 198.51.100.25 a enviar correu del domini, però acaba amb ~all (softfail). Això vol dir que si un atacant envia des d'una altra IP, el servidor receptor NO el rebutja: el marca com a sospitós però sovint l'accepta igual (va a correu brossa o fins i tot a la safata d'entrada). Per tant sí, es podria falsificar el remitent. Per arreglar-ho caldria posar -all (hardfail) en lloc de ~all, i afegir DKIM i DMARC perquè els correus falsos es rebutgin de veritat. La flag és la IP i el qualificador junts: 198.51.100.25~all.

Tasca 7 · Pretext B: suplantar el proveïdor

```
root@vm:~/cas_Operacio_Far$
$ pdfinfo documents/Pla_estrategic_2026.pdf

Title:           Pla estratègic 2026
Subject:         Original a \\\\SRV-NT-FILES\\Direccio\\Pla_2026.docx
Keywords:        FLAG{metadades_de_documents}
Author:          mcasals
Creator:         Microsoft Word 2019
Producer:        Microsoft: Print To PDF

$ pdftotext documents/Pla_estrategic_2026.pdf -   (selecciona i copia tot el text, surt el que estava tapat)

NovaTerra Logística · Pla estratègic 2026
Document de treball intern. Confidencial.


1. Objectius 2026
- Migrar el ERP a LogiCore v3.2 (15 de novembre).
- Obrir un tercer magatzem a la zona nord.


2. Proveïdors clau
Proveïdor de transport: TransIberia SL
Proveïdor cloud: CloudCat Hosting · cuenta cliente NT-48211
Contacte tècnic del proveïdor:            suport@cloudcat.example · 93 111 22 33


3. Accessos temporals durant la migració
Compte de servei de la migració:             svc_migracio
Contrasenya inicial (canviar després):               Migr@cio2026!




Nota interna: FLAG{redactar_no_es_tapar_amb_negre}
```

documents/Pla_estrategic_2026.pdf — proveïdor cloud i compte de client

Flag: `FLAG{NT-48211}`

Resposta: Guió d'una trucada de suport falsa (teòrica):
— Bon dia, truco de CloudCat Hosting, suport tècnic.
— Veig una incidència al vostre compte de client NT-48211 relacionada amb la migració a LogiCore.
— Com que la vostra CTO, la Marina, és fora, parlo amb tu que cobreixes les gestions, oi?
— Per resoldre-ho necessito que em confirmis l'usuari svc_migracio i que validis un accés.
— És urgent, si no ho fem avui la migració del dia 15 s'aturarà.
Dades del document usades: el proveïdor cloud (CloudCat Hosting), el número de compte de client (NT-48211) i el compte de servei de la migració (svc_migracio). Dues preguntes per comprovar que la trucada és falsa: (1) «Quin és el vostre número de tiquet i us puc tornar la trucada al telèfon oficial de CloudCat que tinc al contracte?»; (2) «Per política interna no dono credencials per telèfon; m'ho podeu enviar pel canal de suport verificat?».

Tasca 8 · Cadena d'atac i defensa

Resposta: Cadena d'atac en 5 passos, cada un amb una mesura que el bloquejaria:

- 1) RECOLLIDA (OSINT): llegeixo el web i la xarxa social → trobo persones, correus, vacances i la migració. Defensa: publicar menys informació interna i formar l'equip en OSINT.
- 2) TRIA D'OBJECTIU: escullo en Jordi Puig, que cobreix la CTO (blog). Defensa: no anunciar públicament qui substitueix qui ni les absències.
- 3) PRETEXT: munto un correu/trucada urgent aprofitant la migració del 15-11 i que la CTO és fora. Defensa: tenir un procediment clar per a peticions urgents i verificar-les per un segon canal.
- 4) CREDENCIALS: endevino la contrasenya de la Marina (Kira1988!) i la confirmo a la filtració. Defensa: contrasenyes úniques i llargues + verificació en dos passos (2FA).
- 5) ENTRADA I SUPLANTACIÓ: envio el correu fals perquè l'SPF és ~all i s'accepta. Defensa: posar SPF -all, DKIM i DMARC perquè els correus falsos es rebutgin.

(He fet servir troballes de les tasques 1, 3, 4 i 6.)